INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC 103 - Week 3 Lab Assignment

Risk Assessment and Management Techniques

Social Engineering and Phishing Campaign Simulation for GRC Professionals

Name	Adeshola Oluwole
Registration Number	C1126CGRCE17211
Course	**GRC 103 Risk Assessment and Management Techniques**
Module	**Module 2 — Risk Analysis and Evaluation**
Opens	25 October 2026, 8:00 AM WAT
Due	08 November 2026, 06:18 PM WAT

1. Introduction

GRC analysts, technical vulnerabilities are only one part of the risk landscape. The human element is often the most exploited attack vector. This lab focuses on **social engineering**, specifically phishing, which is the leading cause of data breaches. You will step into the shoes of both an attacker (to understand the mechanics) and a GRC auditor (to measure risk and policy effectiveness). Your goal is not to trick users, but to objectively measure organizational risk and the effectiveness of security awareness controls.

2. Scenario

The CISO is concerned about the organization's resilience to phishing attacks. You have been authorized to conduct a **controlled, internal, and benign phishing campaign** against a test group of users (in this case, a simulated environment). The objective is to gather data on the click-through rate, credential submission rate, and overall user susceptibility to inform future training budgets, policy updates, and risk calculations.

3. Objectives

- Understand the mechanics of a phishing attack from creation to execution.
- Configure and use a phishing framework (GoPhish) to create a convincing campaign.
- Analyze campaign results to calculate key risk metrics.
- Evaluate the effectiveness of existing security controls (like training).
- Formulate data-driven recommendations for management to reduce human risk.

4. Lab Setup

- **Your Machine:** Kali Linux (Attacker/Auditor) - IP: 192.168.x.x
    - *We will install a new tool on Kali for this lab.*
- **Target (Simulated User Environment):** We will simulate the target users by sending emails to ourselves or a test mailbox. No actual users will be targeted.
- **Phishing Framework: GoPhish** (Open-source phishing toolkit).
- **Target Website:** We will clone the login page of a common internal service (e.g., a fake VPN portal hosted on the Kali machine).

5. Step-by-Step Instructions

Phase 1: Setup and Preparation

Step 1: Install GoPhish

- **Task:** Download and set up the phishing framework.
- **Commands:**

➢ ***Download the latest version of GoPhish for Linux (check for the latest version on their website)***
wget https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-64bit.zip

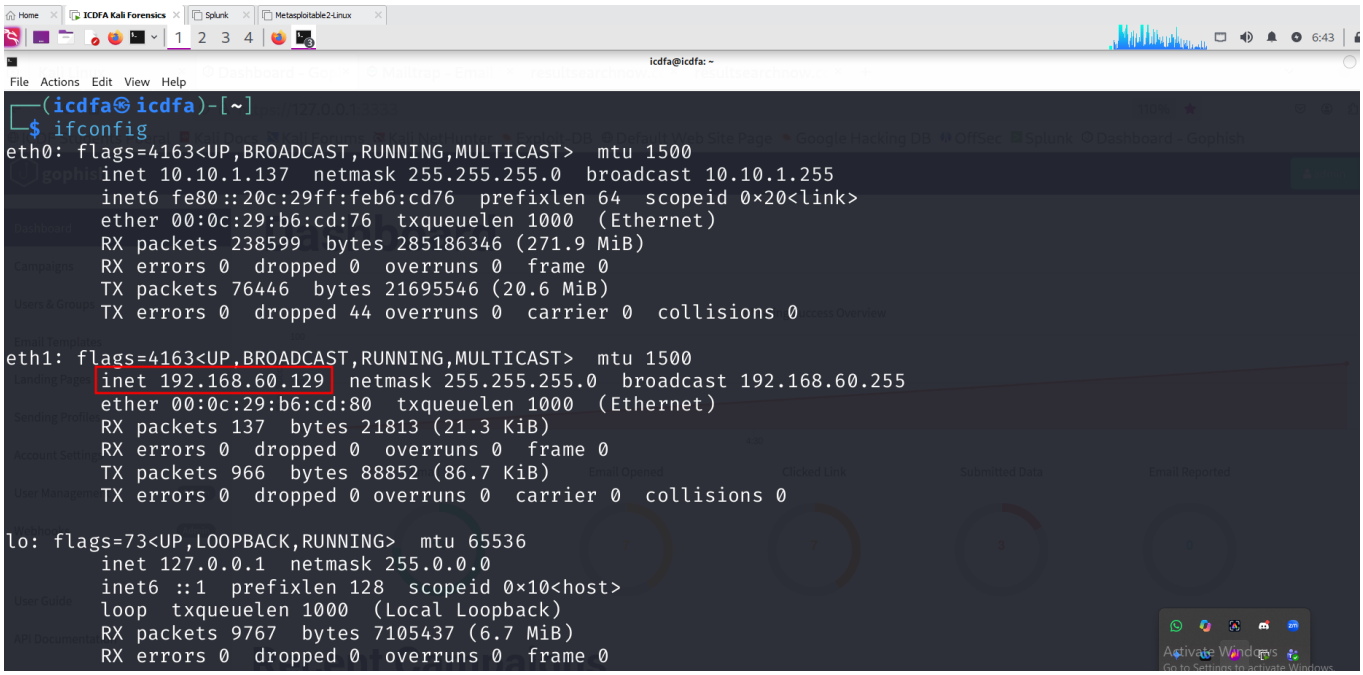
➢ ***Unzip the file***
unzip gophish-v0.12.1-linux-64bit.zip -d gophish/

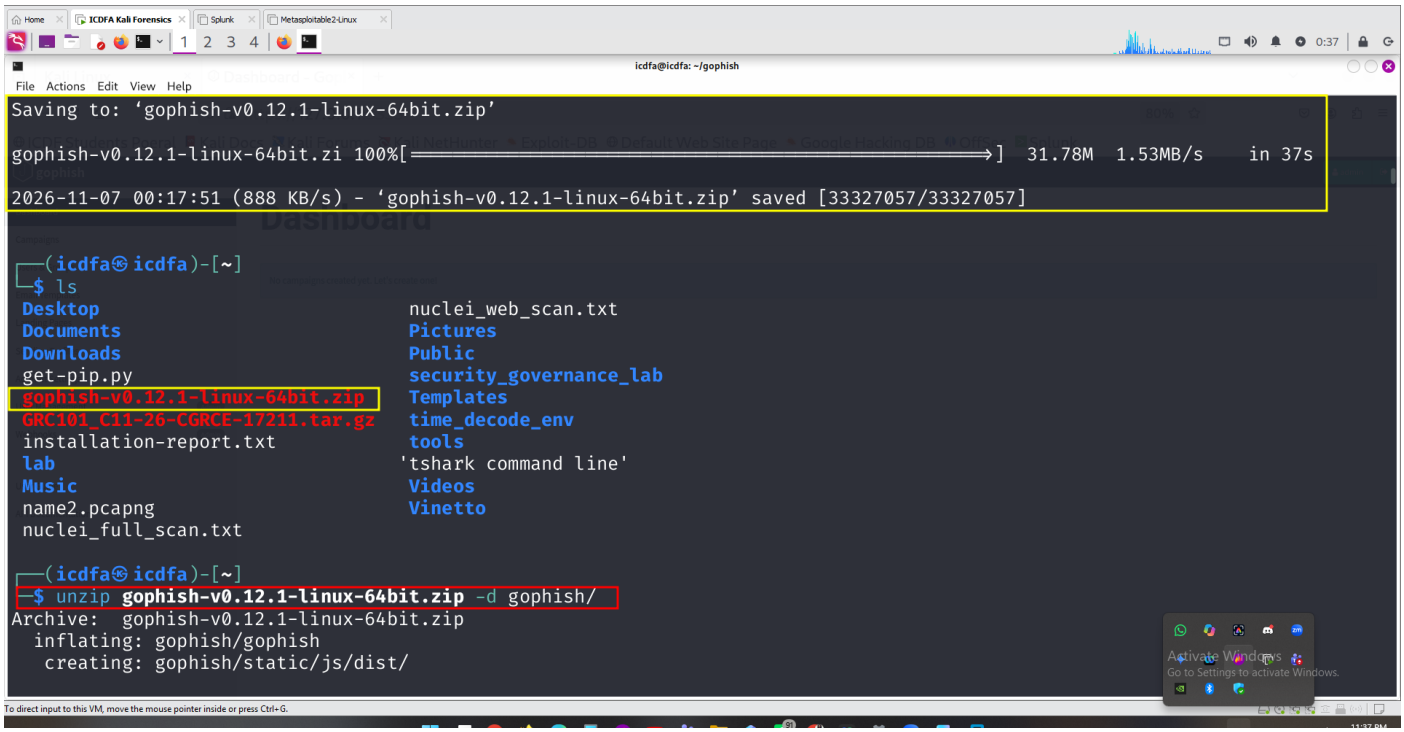
➢ ***Navigate to the directory***
cd gophish/

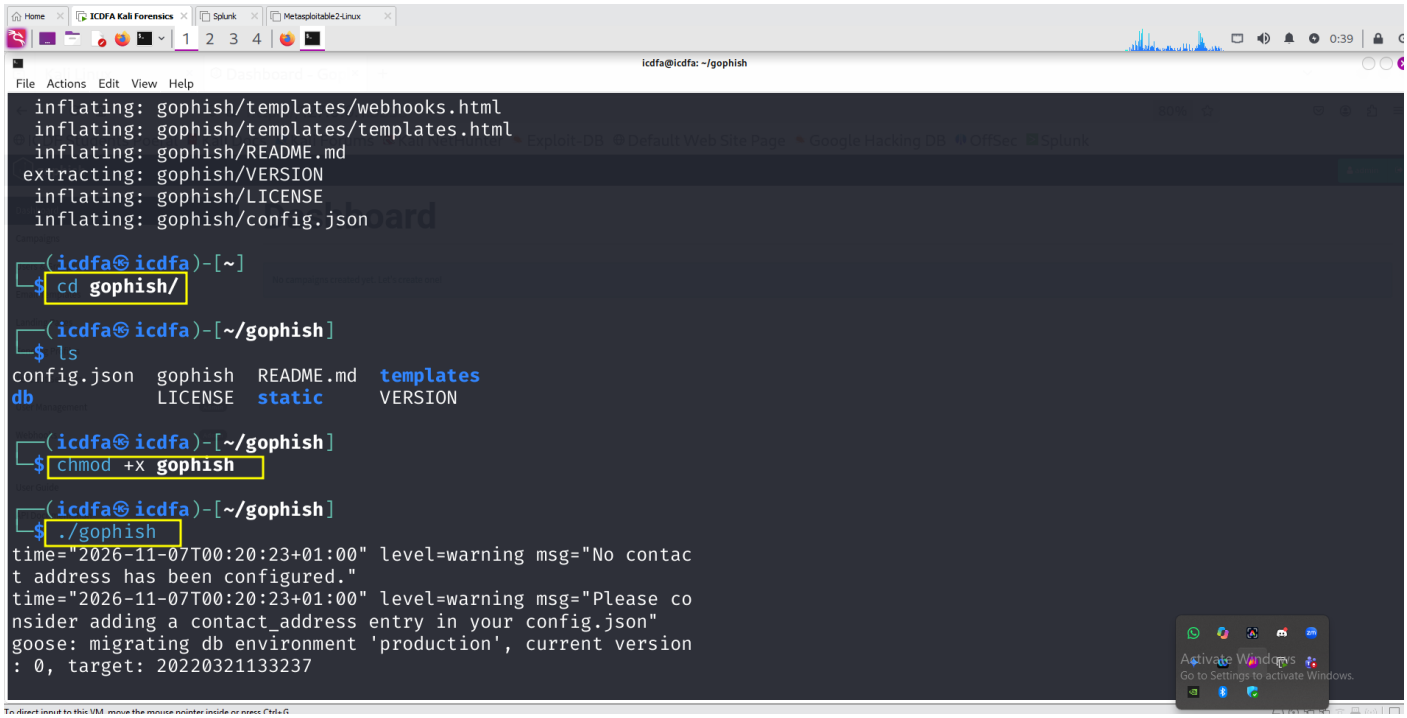
➢ ***Make the binary executable***
chmod +x gophish

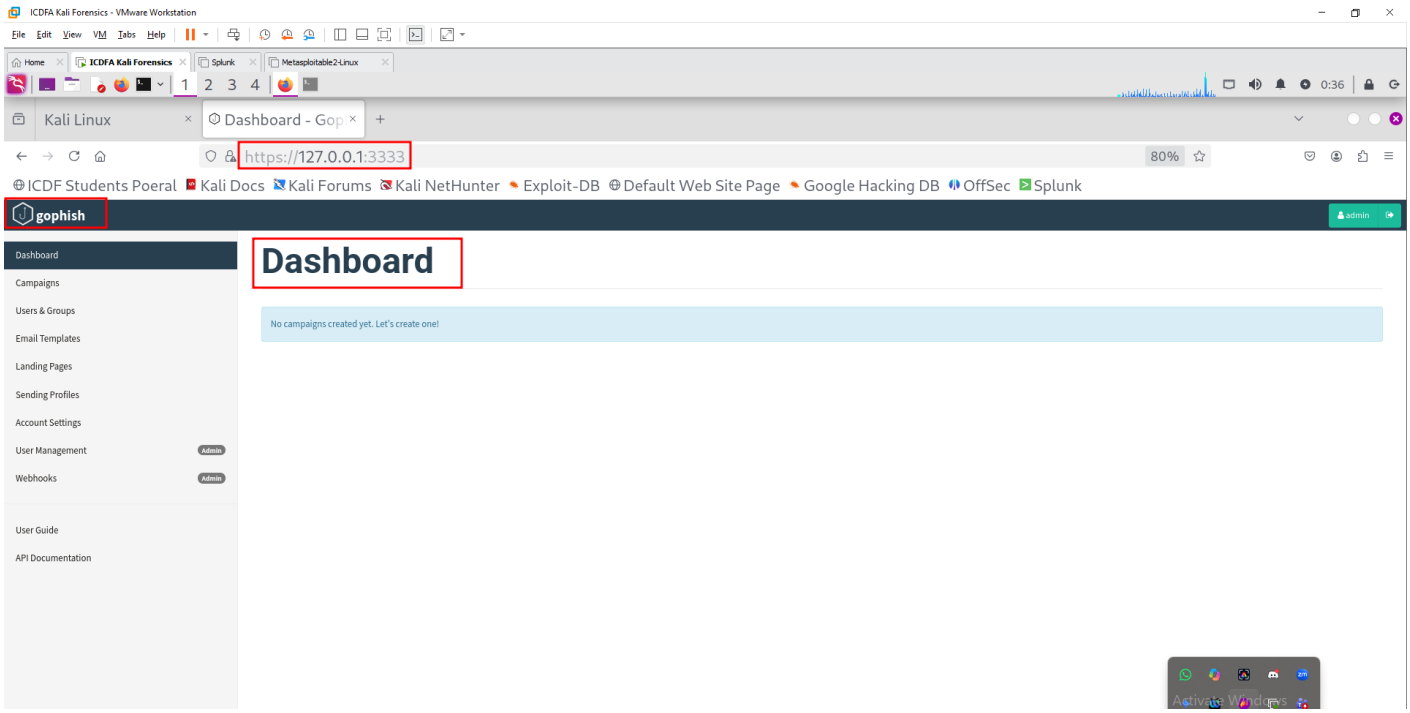
➢ ***Run GoPhish***
./gophish

- **Action:** Note the admin interface URL in the terminal (usually https://127.0.0.1:3333). Open this in your Firefox browser and accept the SSL warning. Log in with the default credentials (admin / gophish).



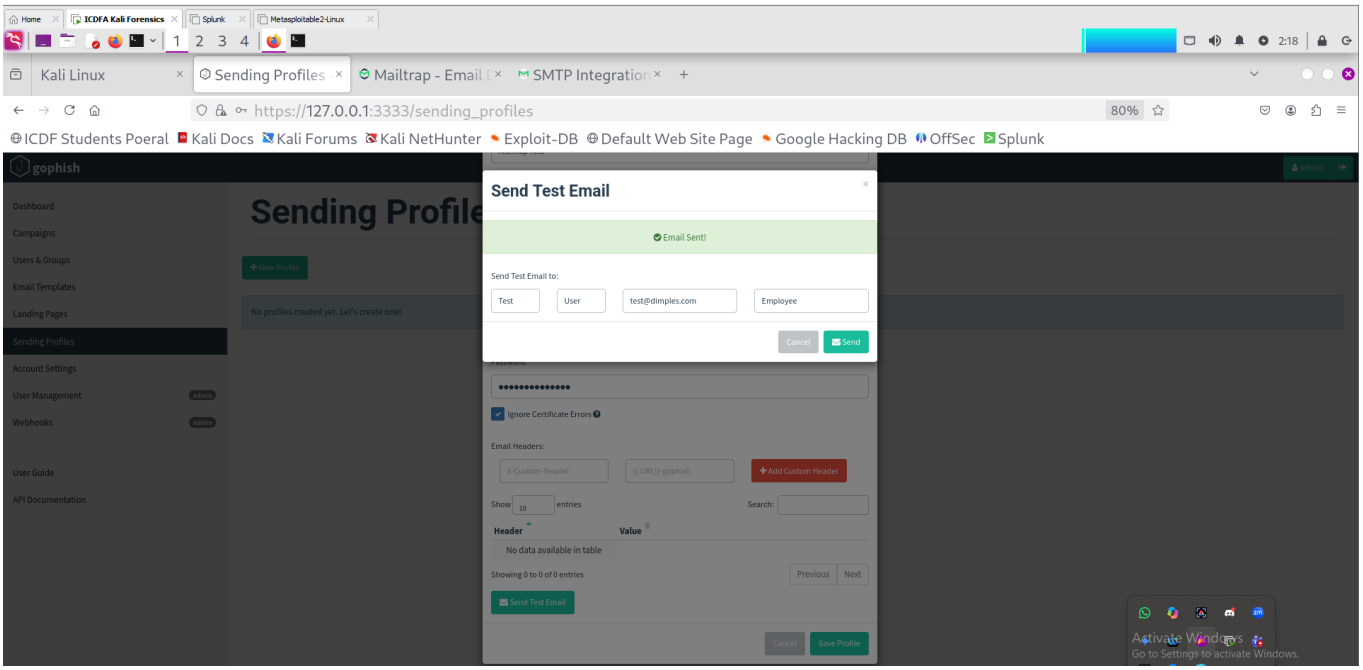

Saving to: ‘gophish-v0.12.1-linux-64bit.zip’
gophish-v0.12.1-linux-64bit.zi 100%[==========>] 31.78M 1.53MB/s in 37s
2026-11-07 00:17:51 (888 KB/s) - ‘gophish-v0.12.1-linux-64bit.zip’ saved [33327057/33327057]
(icdfa㉿icdfa)-[~]
$ ls
Desktop
Documents
Downloads
get-pip.py
gophish-v0.12.1-linux-64bit.zip
GRC101_C11-26-CGRCE-17211.tar.gz
installation-report.txt
lab
Music
name2.pcapng
nuclei_full_scan.txt
nuclei_web_scan.txt
Pictures
Public
security_governance_lab
Templates
time_decode_env
tools
'tshark command line'
Videos
Vinetto
(icdfa㉿icdfa)-[~]
$ unzip gophish-v0.12.1-linux-64bit.zip -d gophish/
Archive: gophish-v0.12.1-linux-64bit.zip
inflating: gophish/gophish
creating: gophish/static/js/dist/


inflating: gophish/templates/webhooks.html
inflating: gophish/templates/templates.html
inflating: gophish/README.md
extracting: gophish/VERSION
inflating: gophish/LICENSE
inflating: gophish/config.json
(icdfa㉿icdfa)-[~]
$ cd gophish/
(icdfa㉿icdfa)-[~/gophish]
$ ls
config.json gophish README.md templates
db LICENSE static VERSION
(icdfa㉿icdfa)-[~/gophish]
$ chmod +x gophish
(icdfa㉿icdfa)-[~/gophish]
$ ./gophish
time="2026-11-07T00:20:23+01:00" level=warning msg="No contact address has been configured."
time="2026-11-07T00:20:23+01:00" level=warning msg="Please consider adding a contact_address entry in your config.json"
goose: migrating db environment 'production', current version: 0, target: 20220321133237



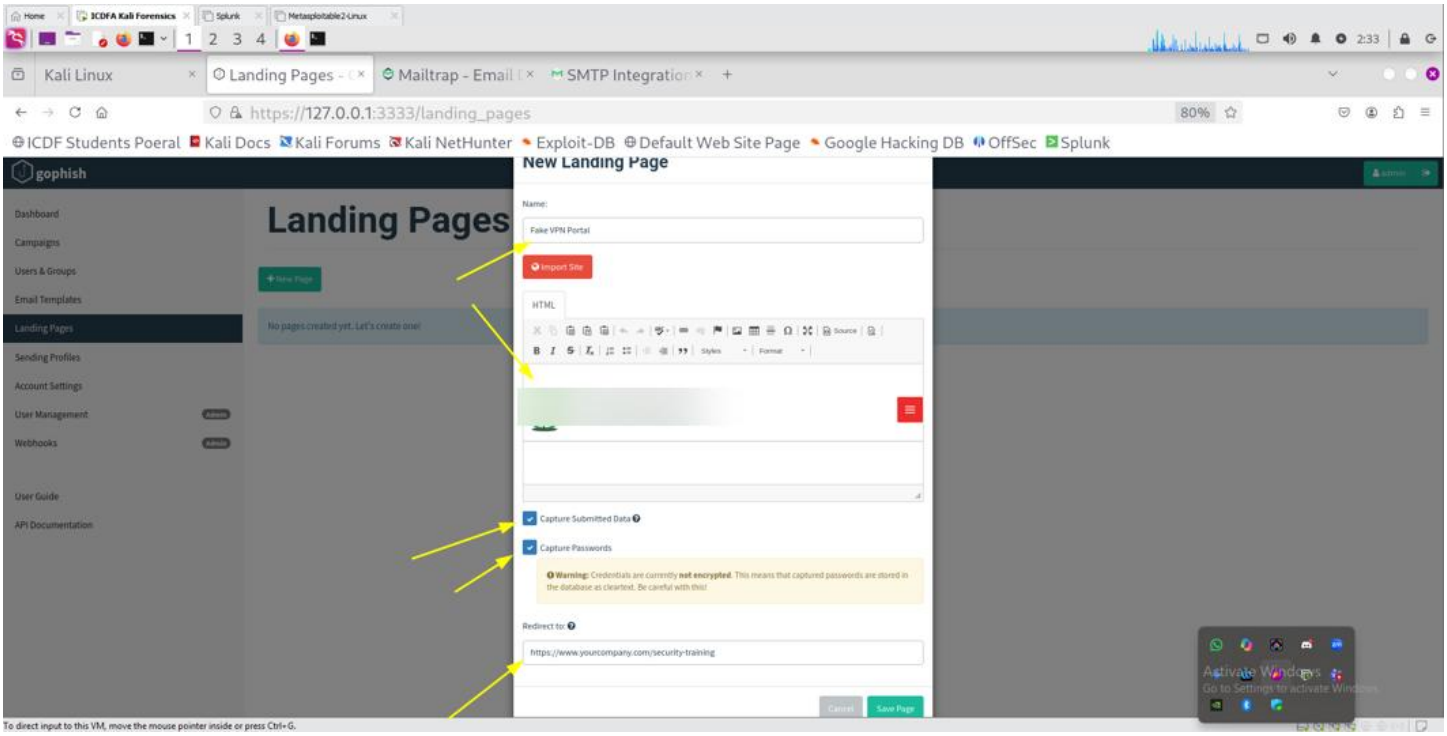
Step 2: Configure Sending Profile

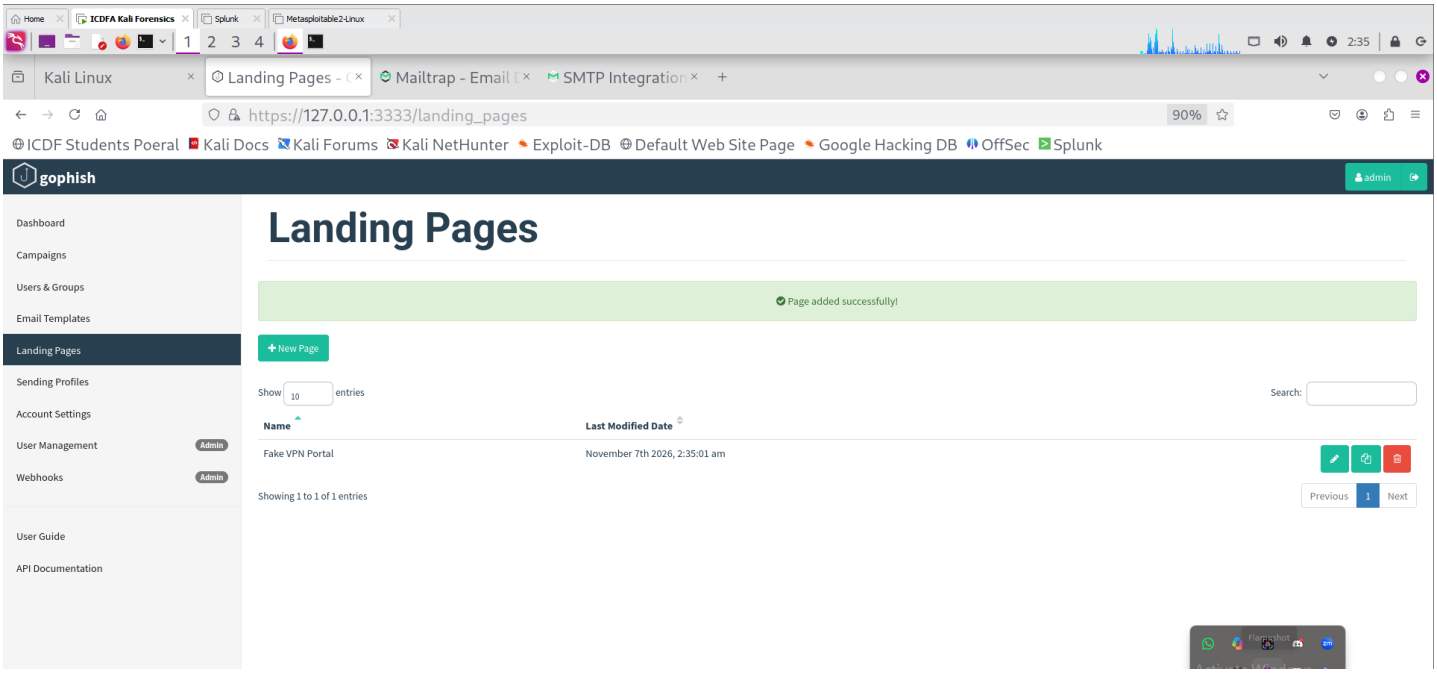
- **Task:** Tell GoPhish how to send emails. For this lab, we will use a local SMTP server or a test service like **Mailtrap.io** (safer and recommended to avoid being flagged as spam).
- **Action (Using Mailtrap - Free Tier):**
    1. Go to https://mailtrap.io/ and create a free account.
    2. In your Mailtrap inbox, find the **SMTP settings** under the "Integrations" tab.
    3. In GoPhish, go to **Sending Profiles** > **New Profile**.
    4. Name: Mailtrap Test
    5. From: Security Team <security-test@yourcompany.com> (Use a convincing alias).
    6. Use the Host, Port, Username, and Password provided by Mailtrap.
    7. Click **Save Profile**.



Step 3: Create a Landing Page

- **Task:** Clone a legitimate login page to use as the phishing destination.
- **Action:**
    1. In GoPhish, go to **Landing Pages** > **New Page**.
    2. Name: Fake VPN Portal
    3. HTML: Click **Import Site**. Enter the URL of a common login page you want to clone (e.g., your university's VPN portal, a fake internal wiki, or even a Microsoft O365 login). GoPhish will fetch the HTML.
    4. **Critical GRC Step:** Check the box **"Capture Submitted Data"** and **"Capture Passwords"**. This is how we will measure success. Also, check **"Redirect to"** and enter a URL like https://www.yourcompany.com/security-training to simulate sending users to a training page after they "log in".





Step 4: Create an Email Template

- **Task:** Craft a convincing phishing email.
- **Action:**
    1. Go to **Email Templates** > **New Template**.

2. Name: VPN Password Reset Required
3. Subject: Action Required: Your VPN Password Expires in 24 Hours
4. HTML: Click **Import Site** and paste the HTML of a well-crafted professional email. Alternatively, write a simple text:

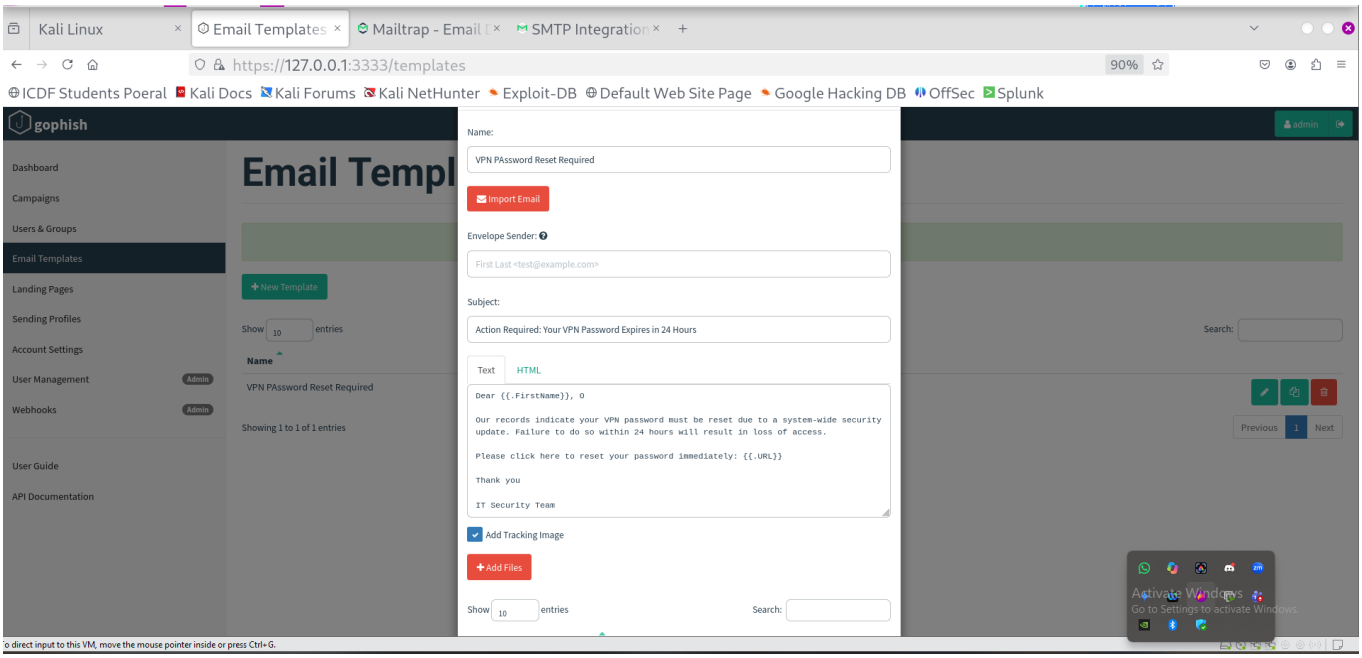
html
Dear {{.FirstName}},
**

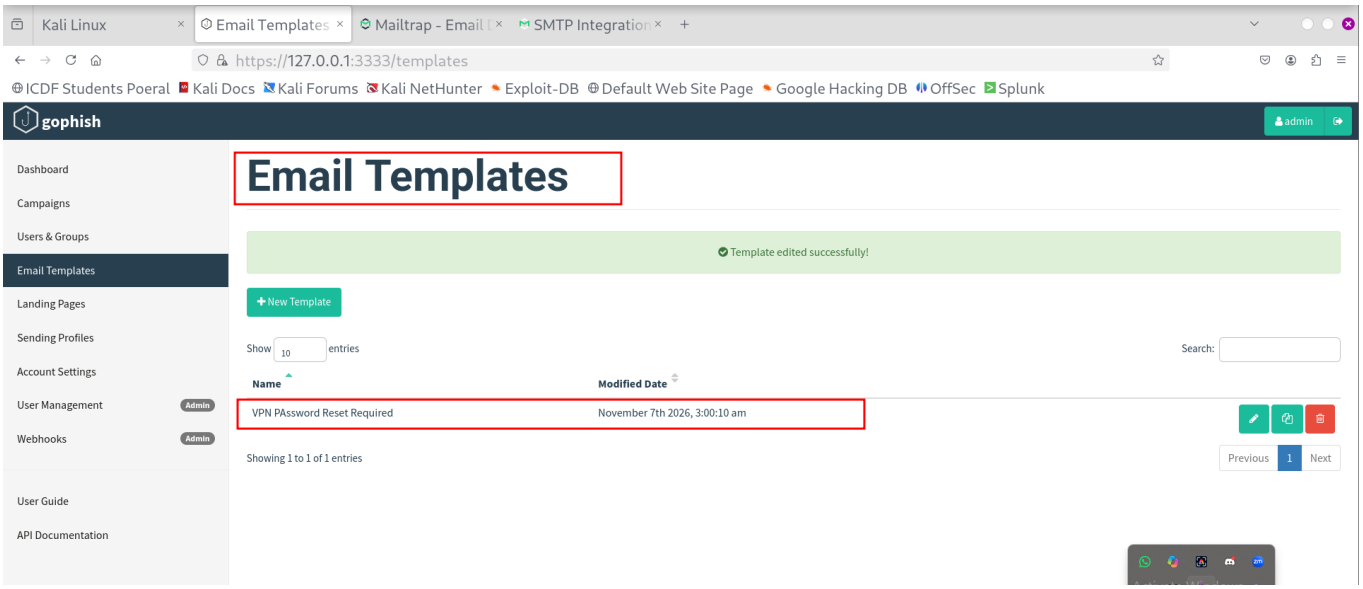
**
Our records indicate that your VPN password must be reset due to a system-wide security update. Failure to do so within 24 hours will result in loss of access.
**

**
Please click here to reset your password immediately: {{.URL}}
**

**
Thank you,
**
**
IT Security Team

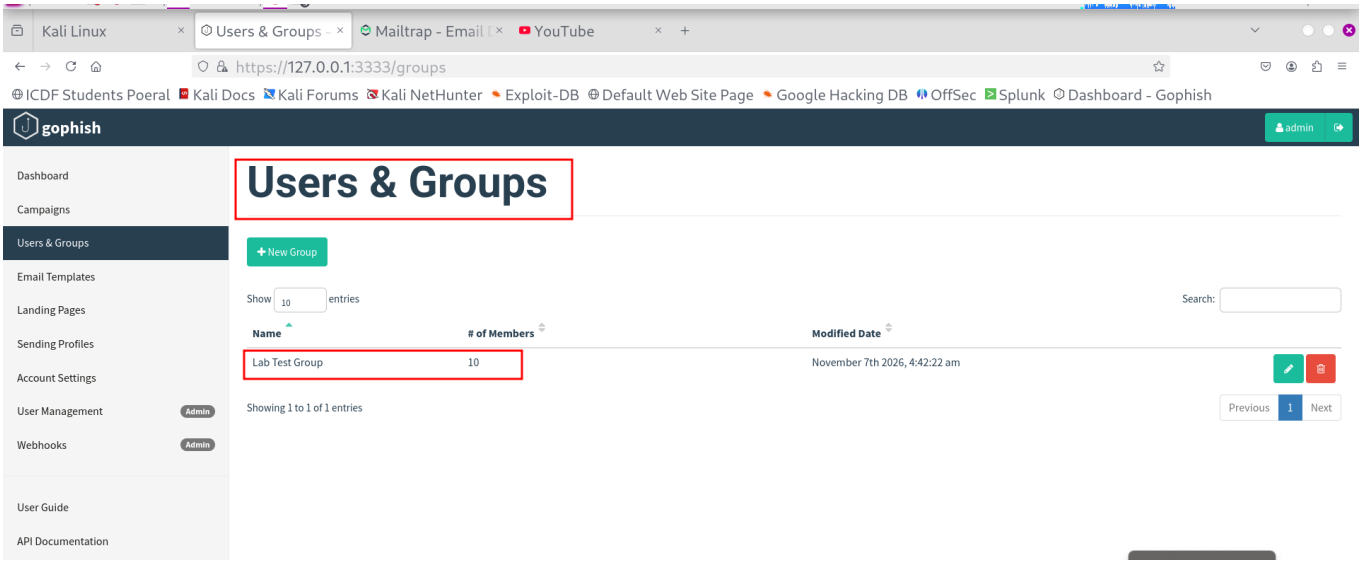
5. Note the use of {{.FirstName}} and {{.URL}}. These are GoPhish variables for personalization and the phishing link.





Step 5: Define Your Target Group

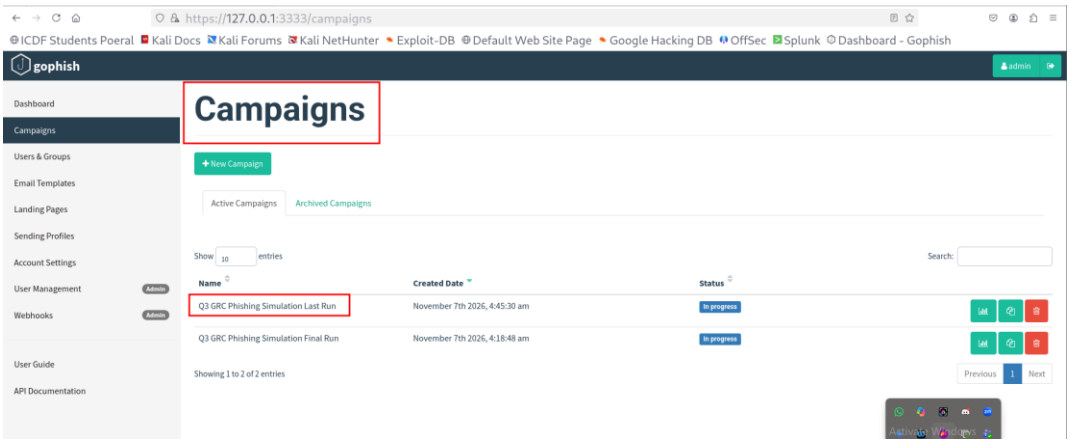
- **Task:** Create a group of test users. Since this is a lab, we will use ourselves.
- **Action:**
    1. Go to **Users & Groups** > **New Group**.
    2. Name: Lab Test Group
    3. Add yourself as a target. Example:
        - Email: your.test.email@gmail.com (or a test account)
        - First Name: Lab
        - Last Name: User
        - Position: Employee
        - *In a real audit, this would be a CSV import of the test department.*

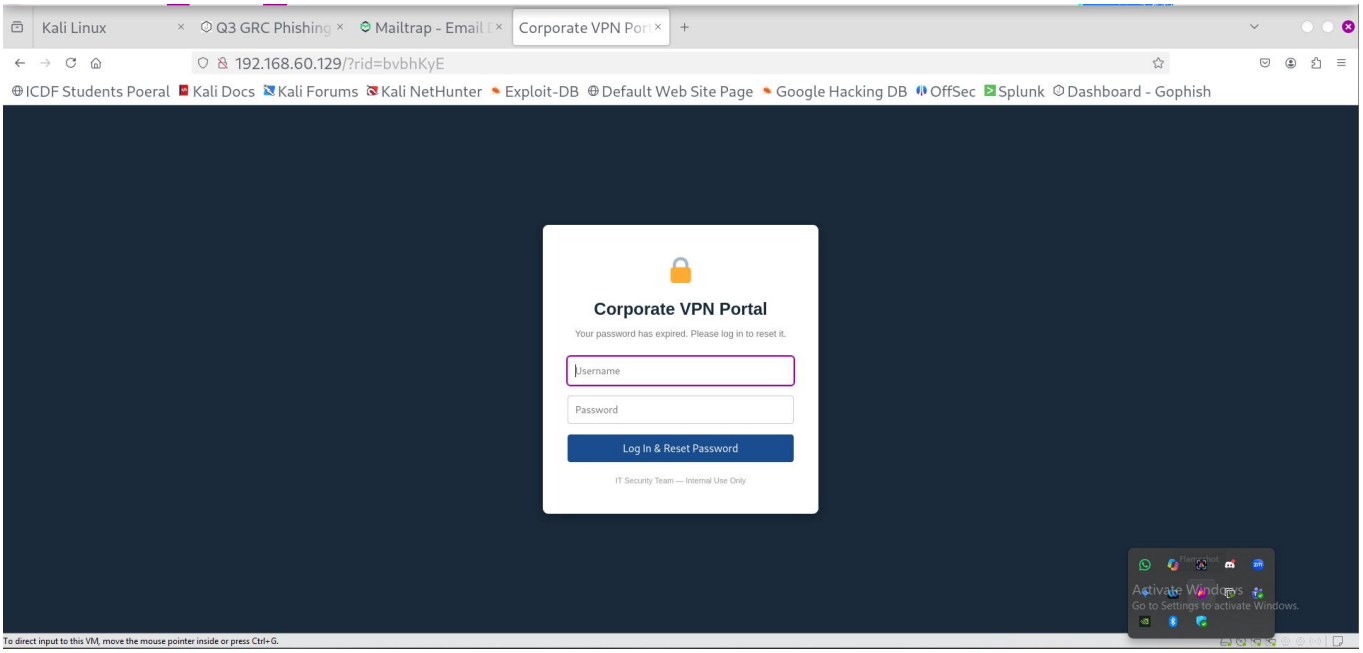


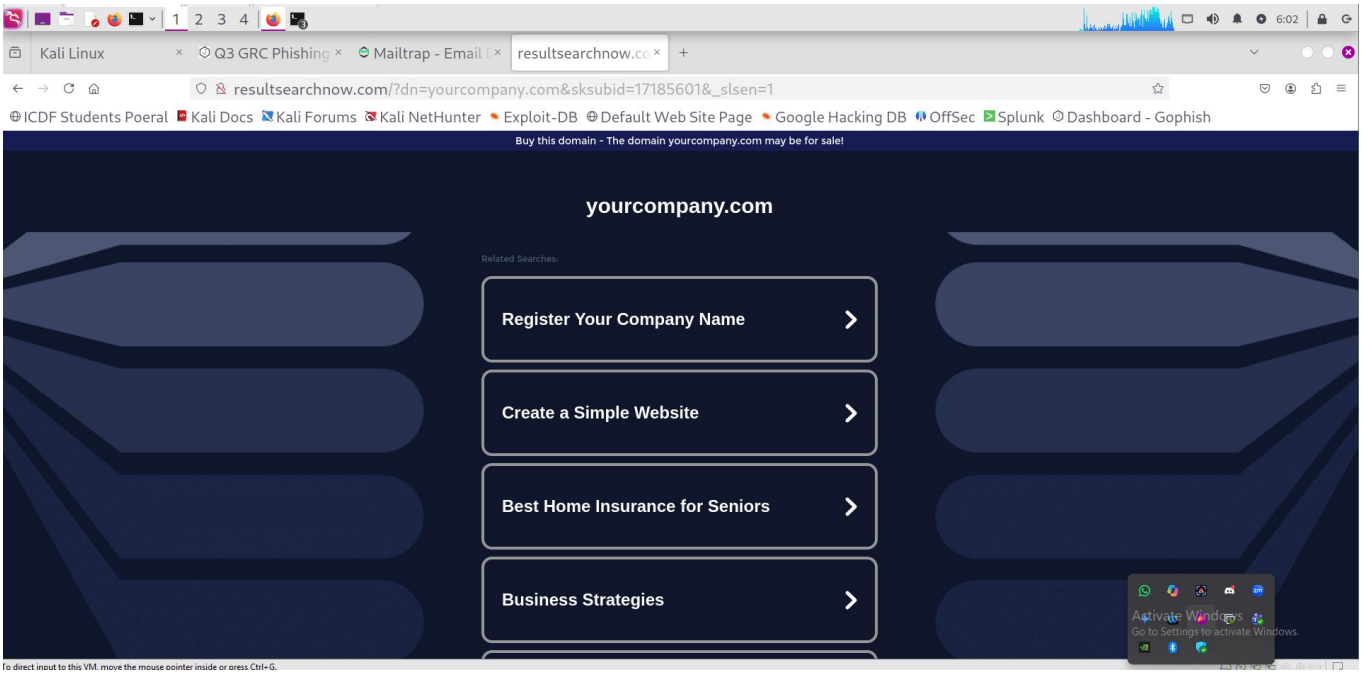
Phase 2: Launching the Campaign

Step 6: Launch the Phishing Campaign

- **Task:** Execute the simulated attack and collect data.
- **Action:**
    1. Go to **Campaigns** > **New Campaign**.
    2. Name: Q3 GRC Phishing Simulation
    3. Select the Email Template, Landing Page, Sending Profile, and Target Group you just created.
    4. Set a URL to mask the phishing link (e.g., https://vpn-yourcompany.com). GoPhish will handle this.
    5. Set the campaign to launch **immediately**.
    6. Click **Launch Campaign**.







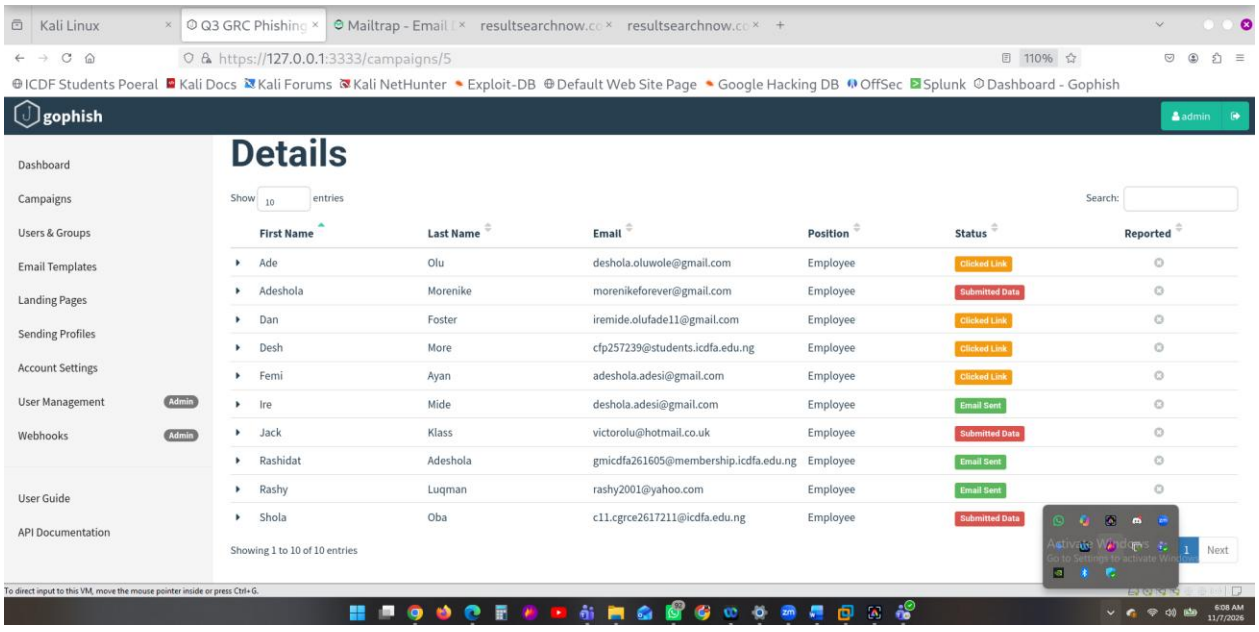
Phase 3: Monitoring and Analysis (The GRC Core)

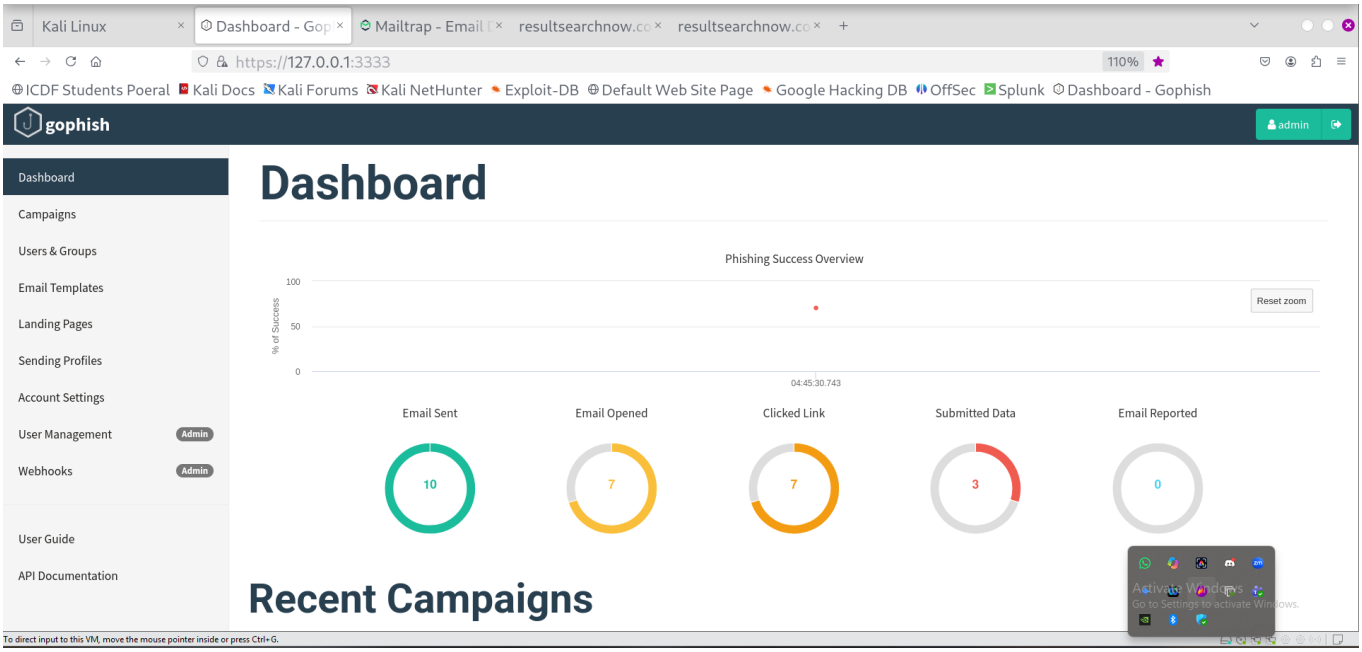
Step 7: Analyze the Results

- **Task:** Review the data collected to calculate key risk metrics.
- **Action:**
    1. Go back to the **Dashboard** or **Campaigns** view and click on your running campaign.

2. Monitor the results in real-time:
    - **Email Sent:** Number of emails successfully sent.
    - **Opened:** How many users opened the email (risk metric: curiosity/susceptibility).
    - **Clicked Link:** How many users clicked the link (risk metric: failure to hover and verify).
    - **Data Submitted:** How many users entered their (fake) credentials (critical risk metric).
    - **GRC Context:** These metrics directly quantify the human risk component of your organization.







Step 8: Triage and Risk Assessment

Create a table with your findings and their implications.

Metric	Result	Calculated Rate	Risk Interpretation	Control Failure
Emails Opened	7/10	70%	High engagement with the themed lure; most recipients did not filter it out at the inbox level.	Security awareness training is not effectively reducing initial engagement with suspicious emails.
Links Clicked	7/10	70%	Every recipient who opened the email also clicked the link — a 100% click-through rate among openers. High risk of users executing malicious actions once an email reaches them.	Email filtering may be ineffective; Users are not pausing to verify sender identity or hover/inspect links before clicking.
Credentials Submitted	3/10	30%	Significant Risk. Nearly a third of all targeted employees would have handed over real credentials to an attacker	Multi-Factor Authentication (MFA) would prevent these captured credentials from translating into actual account compromise.
Phishing Reported	0/10	0%	No recipient used a formal reporting channel to flag the email, even among those who did not fall for it.	No active “Report Phishing” mechanism or habit currently exists among staff — a detection gap, not just a prevention gap.

Step 9: Drafting the Executive Summary & Recommendations

To: CISO, Head of HR, and Executive Management
From: GRC Audit Team
Date: November 7 2026
Subject: Results of Q3 Controlled Phishing Simulation and Human Risk Assessment

1. Executive Summary:

A controlled phishing simulation was conducted to assess organizational resilience to social engineering attacks. The results indicate a **significant level of human risk**, with 30% of targeted employees submitting credentials to a simulated malicious site, and 70% clicking through to the fake login page in the first place. This represents a material threat to our information assets and indicates gaps in both prevention and detection.

2. Key Findings & Metrics:

- **Email Open Rate:** 70% - indicating meaningful engagement with themed emails.
- **Link Click-Through Rate:** 70% - indicating a widespread failure to identify or pause on suspicious links; notably, 100% of employees who opened the email went on to click it.
- **Credential Submission Rate:** 30% - **This is the most critical finding.** Nearly 1 in 3 employees tested would have compromised their corporate credentials in a real attack.
- **Reporting Rate:** 0% — no employee used a reporting mechanism to flag the suspicious email, suggesting a detection and response gap alongside the prevention gap.

3. Risk Analysis:

This data reveals that current security awareness measures are not sufficiently reducing susceptibility to social engineering. A successful real phishing attack exploiting this behavior pattern could lead to:

- Initial network access for attackers via compromised credentials.
- Data breaches and associated financial loss.
- Reputational damage and regulatory exposure (e.g., under GDPR, CCPA, or similar frameworks).
- Delayed incident response, given the 0% reporting rate means security teams would likely learn of a real attack only after damage occurs.

4. Recommended Actions:

1. **Immediate Technical Control: Accelerate the rollout of Multi-Factor Authentication (MFA)** across all critical systems. the single most effective control to neutralize the risk of stolen credentials.
2. **Revamp Training Program:** Shift from static annual compliance training to **continuous, scenario-based training** that reflects real lure patterns (urgency, authority, plausible pretext).
3. **Introduce a Reporting Mechanism:** Deploy a one-click "Report Phishing" button in the email client and actively promote its use — the 0% reporting rate is as urgent a finding as the 30% credential-submission rate.
4. **Process Integration:** Integrate phishing simulations into onboarding for new hires and run them quarterly for all staff, tracking rate trends over time.
5. **Policy Update:** Review and update the **Acceptable Use Policy (AUP)** to explicitly define employee responsibilities for identifying and reporting phishing attempts.

6. Lab Conclusion

This lab showed that cybersecurity is not just about technical vulnerabilities but also about human behaviour. By carrying out a phishing simulation from start to finish, using GoPhish, a sandboxed mail relay and a cloned login page, I was able to see how easily attackers can trick people into giving away sensitive information. The results were quite revealing: 70% of the test group clicked the phishing link, while 30% submitted their credentials. This happened even though the participants knew they were taking part in a cybersecurity exercise.

The exercise also highlighted the importance of collecting accurate data during security assessments. For example, the third-party email sandbox initially blocked some messages because of its sending limit. There was also a mismatch between the password reset email and the first version of the cloned landing page, which could have affected the results. Identifying and fixing these issues before analysing the findings showed why checking data quality is an important part of risk management.

Overall, this lab helped me understand the role of a GRC professional in turning technical findings into practical business recommendations. It is not enough to identify security weaknesses; they must also be explained in terms of the risks they create for an organisation. The findings showed the need for stronger controls, such as multi-factor authentication (MFA), an effective phishing reporting process and regular security awareness training. These recommendations can help the management understand the risks and make informed decisions about investing in better security controls.